Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-20 09:00 WIB

Top 5 Highlights

- Threat Brief: Active Exploitation of PAN-OS CVE-2026-0257 (Updated October 19)
- Nikkei discloses third data breach in a month, 1.8M records exposed
- WordPress SEO plugin Rank Math compromised to backdoor websites
- Researchers Infiltrate Microsoft Tech Support Scam Operation
- Attackers compromise Microsoft 365 credential via ConnectWise Cloud Backup

Threat Intelligence (10)

01. WordPress SEO plugin Rank Math compromised to backdoor websites

Some downloads of the Rank Math PRO WordPress plugin from the vendor's official website carried malware that planted hidden backdoors in a supply-chain attack last week. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/wordpress-seo-plugin-rank-math-compromised-to-backdoor-websites/

02. Hackers hijack AOMEI update servers to secretly spread malware

Hackers reportedly compromised AOMEI's servers to distribute malware through a built-in promotional feature in its backup software, briefly tampering with configuration files before restoring them to their original state to hide the attacks.a [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/hackers-hijack-aomei-update-servers-to-secretly-spread-malware/

03. Popular WordPress SEO Plugin Rank Math PRO Hijacked to Deliver Self-Restoring Backdoor

Copies of Rank Math PRO, the paid version of the Rank Math SEO plugin for WordPress, that were downloaded from rankmath.com or delivered as updates between 20:02 UTC on October 15 and 07:12 UTC on October 16 contained malware, Rank Math said in a security notice published on October 16. Any site that installed and activated one of those copies should be tre…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/popular-wordpress-seo-plugin-rank-math.html

04. Rank Math PRO WordPress Plugin Compromised in Supply Chain Attack

Hackers injected malware into Rank Math PRO version 3.0.123 packages distributed between October 15 and October 16. The post Rank Math PRO WordPress Plugin Compromised in Supply Chain Attack appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.securityweek.com/rank-math-pro-wordpress-plugin-compromised-in-supply-chain-attack/

05. Vishing (voice phishing): how the attack works and how to stop it

Vishing (voice phishing): how the attack works and how to stop it

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.scworld.com/tech-explainer/vishing-voice-phishing-how-the-attack-works-and-how-to-stop-it

06. Fake WatchGuard website steals VPN credentials with legitimate software download

A sophisticated phishing scheme has been uncovered where a fake WatchGuard VPN website successfully stole administrator credentials by posing as a legitimate download portal.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.scworld.com/brief/fake-watchguard-website-steals-vpn-credentials-with-legitimate-software-download

07. Smishing (SMS phishing): how the attack works and how to stop it

Smishing (SMS phishing): how the attack works and how to stop it

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.scworld.com/tech-explainer/smishing-sms-phishing-how-the-attack-works-and-how-to-stop-it

08. AOMEI Backupper update servers hijacked to push malware: Check your PC

Attackers tampered with AOMEI Backupper’s update system to deliver malware that could give them remote access to users’ PCs.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.malwarebytes.com/blog/news/2026/10/aomei-backupper-update-servers-hijacked-to-push-malware-check-your-pc

09. Unmasking the robots: Why it’s critical to discover AI agent identities and how Tenable helps you secure them

Discover how to secure AI agents in your cloud environment with Tenable One Cloud Exposure. We explore Microsoft Entra Agent ID and provide essential best practices for robust agentic AI identity security. Key takeaways Understand your current maturity level and then build an appropriate action plan to secure your agent identities. Use your cloud providers’…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.tenable.com/blog/secure-ai-agent-identities-microsoft-entra-agent-id-tenable-one

10. GhostAction Attackers Plant Credential Stealer Disguised as Font in 94 GitHub Repositories

The threat actor behind the GhostAction supply chain attack has expanded beyond injecting malicious GitHub Actions workflows into compromised projects to phish open-source developers and deliver a stealer malware disguised within a fake font file. The latest evolution, detailed by OpenSourceMalware, signals that the attackers are actively refining their mod…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://thehackernews.com/2026/10/ghostaction-attackers-plant-credential.html

Latest Vulnerabilities (10)

01. Threat Brief: Active Exploitation of PAN-OS CVE-2026-0257 (Updated October 19)

Ransomware operators including Spikey Scorpius (aka Qilin) and Tarnished Scorpius (aka Inc) are exploiting PAN-OS vulnerability CVE-2026-0257. The post Threat Brief: Active Exploitation of PAN-OS CVE-2026-0257 (Updated October 19) appeared first on Unit 42 .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://unit42.paloaltonetworks.com/active-exploitation-of-pan-os-cve-2026-0257/

02. Grocery giant Ahold Delhaize confirms cyberattack forced US and European systems offline

Second security snafu in two years

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/19/grocery-giant-ahold-delhaize-confirms-cyberattack-forced-us-and-european-systems-offline/5303970

03. 'AdFection' Turns Ad Impressions Into Zero-Click Spyware Delivery

Spyware vendors are exploiting targeted ad bidding in the digital ecosystem to identify and track individuals and organizations of interest.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/data-privacy/adfection-online-ads-spyware-delivery

04. Security patches need patches now that attackers have AI

Terra finds sharp rise in GitHub security fixes reported broken within 90 days

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/patches/2026/10/19/security-patches-need-patches-now-that-attackers-have-ai/5303927

05. Siemens Software Center Vulnerability Exploited in ClickFix Malware Attacks

Attackers paired a genuine, signed copy of Siemens Software Center with malicious DLLs to infect Windows PCs via ClickFix lures. The post Siemens Software Center Vulnerability Exploited in ClickFix Malware Attacks appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.securityweek.com/siemens-software-center-vulnerability-exploited-in-clickfix-malware-attacks/

06. Hackers Exploit Plex2Shell Flaws to Install Crypto Miners and Linux Proxy Backdoor

Threat actors have begun to exploit a chain of vulnerabilities in Plex Media Server to deploy cryptocurrency miners and reverse proxy software, a day after a proof-of-concept (PoC) went public. According to a researcher who goes by the online alias boredhackerblog, the exploitation activity involves chaining four different vulnerabilities,

collectively call…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/hackers-exploit-plex2shell-flaws-to.html

07. OpenCode hack exposes API keys amid AI distillation attacks

The open-source AI coding project OpenCode has notified a small number of users that API keys they used with external providers were exposed in a security breach. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/opencode-hack-exposes-api-keys-amid-ai-distillation-attacks/

08. Drupal Warns of Fast Exploitation Risk for Critical Core RCE Flaw

Critical flaws impact the Entity List and Field UI modules, and exploit paths exist with contributed modules. The post Drupal Warns of Fast Exploitation Risk for Critical Core RCE Flaw appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.securityweek.com/drupal-warns-of-fast-exploitation-risk-for-critical-core-rce-flaw/

09. Exploited Vulnerabilities Typically Take Three Months to Patch, Moody’s Finds

Known exploited vulnerabilities take a median time of 87 days to be patched, according to a new Moody’s report

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.infosecurity-magazine.com/news/exploited-vulnerabilities-three/

10. CISA adds Fortinet and BeyondTrust vulnerabilities to exploited list

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) has added two critical vulnerabilities affecting Fortinet products and BeyondTrust Remote Support to its Known Exploited Vulnerabilities (KEV) catalog.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/cisa-adds-fortinet-and-beyondtrust-vulnerabilities-to-exploited-list

Data Breach & Cybercrime (10)

01. Nikkei discloses third data breach in a month, 1.8M records exposed

Nikkei Inc. disclosed a new data breach, the third in about a month, that exposed 1.83 million personal information records. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/nikkei-discloses-third-data-breach-in-a-month-18m-records-exposed/

02. Researchers Infiltrate Microsoft Tech Support Scam Operation

A large-scale scam operation impersonating Microsoft uses a malicious traffic distribution system (TDS) run by a Russian organization and abuses thousands of Cloudflare links.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/threat-intelligence/microsoft-tech-support-scam-operation

03. Attackers compromise Microsoft 365 credential via ConnectWise Cloud Backup

Stolen ConnectWise app credential enables unauthorized access to hundreds of Microsoft 365 tenants.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/news/attackers-compromise-microsoft-365-credential-via-connectwise-cloud-backup

04. 19th October - Threat Intelligence Report

For the latest discoveries in cyber research for the week of 19th October, please download our Threat Intelligence Bulletin. TOP ATTACKS AND BREACHES CenterPoint Energy, a US utility company serving Texas and several other states, has disclosed a data breach affecting more than 1 million Texas residents. Unauthorized access to an external system exposed nam…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://research.checkpoint.com/2026/19th-october-threat-intelligence-report/

05. Conduent Agrees to Pay $80m to Settle Data Breach Class Action

The 2024 cyber incident affected the healthcare data of 62 million people, who launched a class action lawsuit against the business services firm

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.infosecurity-magazine.com/news/conduent-settle-data-breach-action/

06. Inside the Underground Market for Know Your Client Services

Cybercriminals are selling forged identity documents, deepfake videos, and live verification services to help buyers bypass Know Your Client (KYC) checks. Flare examines how these underground services operate and the techniques used to create and maintain fraudulent verified accounts. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/inside-the-underground-market-for-know-your-client-services/

07. Feds Suspect Ransom Negotiator Ran ShinyHunters Extortion Site

U.S. federal investigators pursuing the ShinyHunters hacking group that recently stole highly sensitive data from the FBI have identified executives at two different ransomware negotiation firms who maintained unusually close relations with the extortion group, KrebsOnSecurity has learned. Sources close to the investigation say one of the executives in the…

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://krebsonsecurity.com/2026/10/feds-suspect-ransom-negotiator-ran-shinyhunters-extortion-site/

08. OpenCode Breach Could Affect OpenAI, Anthropic and Google

A breach affecting the OpenCode Console may lead to the exposure of API keys for Anthropic, OpenAI and Google Gemini users

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.infosecurity-magazine.com/news/opencode-breach-openai-anthropic/

09. Bring Your Own Vulnerable Driver: What Detection Teams Should Actually Hunt

Discover how detection teams can split EDR-killer attacks into four distinct behavior hunts to catch BYOVD and driverless threats before ransomware fires.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.sentinelone.com/blog/bring-your-own-vulnerable-driver-what-detection-teams-should-actually-hunt/

10. A sextortion conspiracy killed his son (Lock and Code S07E21)

This week on the Lock and Code podcast, we speak with John DeMay about a sextortion plot that targeted his son on the night of his suicide.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/podcast/2026/10/a-sextortion-conspiracy-killed-his-son-lock-and-code-s07e21